

SECURITY ASSESSMENT REPORT

Project Name: OWASP Top 10 Security Assessment Toolkit for a Restaurant Chain

Assigned Role: Member 2 (Individual Contributor)

Primary Security Tool: Burp Suite

Testing Environments: PortSwigger Web Security Academy & OWASP Juice Shop (Authorized Labs)

1. Executive Summary

An authorized web application security assessment was conducted targeting critical components of the Restaurant Chain application infrastructure. Testing focused on identifying and validating security vulnerabilities within the OWASP framework using Burp Suite Community Edition.

Two primary vulnerabilities were successfully identified, exploited in controlled environments, and documented with complete Proof-of-Concept (PoC) evidence:

- 1. Broken Access Control (OWASP A01:2021) – High Severity
- 2. Security Misconfiguration: Directory Listing (OWASP A05:2021) – Medium Severity

2. Assessment Findings Summary

Vulnerability Title	OWASP Category	CVSS v3.1	Severity	Target Environment	Status
Direct Admin Access Bypass	A01:2021 - Broken Access Control	7.5	HIGH	PortSwigger Academy	Confirmed / Exploited
Unrestricted Directory Listing	A05:2021 - Security Misconfiguration	5.3	MEDIUM	OWASP Juice Shop	Confirmed

3. Detailed Technical Findings

3.1. Finding 1: Broken Access Control (OWASP A01:2021)

- **Vulnerability Title:** Unauthorized Administrative Access via Unprotected Endpoint (/administrator-panel)
- **Severity Rating:** High
- **Affected Endpoint:** /administrator-panel
- **Testing Methodology:**
 - Base network traffic was intercepted using the Burp Suite Built-in Browser.
 - The HTTP request was forwarded to Burp Repeater.
 - The target URI path was modified from / to /administrator-panel without supplying administrative cookies or session tokens.
 - The response was analyzed for authorization enforcement.
- **Detailed Observation:**

The web application relies on URL obscurity rather than enforcing server-side authorization checks. Upon submitting the request to /administrator-panel, the server responded with HTTP/1.1 200 OK and rendered the full administrative console. An unauthenticated attacker can directly invoke administrative actions, such as executing user account deletion requests (e.g., deleting user carlos).
- **Business Impact:**

In a live restaurant application, an unauthorized attacker exploiting this vulnerability could delete customer profiles, wipe order histories, disrupt point-of-sale (POS) systems, and manipulate administrative configuration settings.
- **Remediation Strategy:**
 - Role-Based Access Control (RBAC): Enforce strict server-side RBAC on all administrative routes.
 - Deny by Default: Reject all unauthenticated HTTP requests to /administrator-panel with an HTTP 403 Forbidden or 401 Unauthorized status.
 - Eliminate Obscurity Reliance: Do not rely on hidden client-side URLs or unlisted routes for access control.

Proof of Concept Evidence :

Figure 1.1: Burp Suite Repeater showing modified request to /administrator-panel and receiving HTTP/1.1 200 OK response:

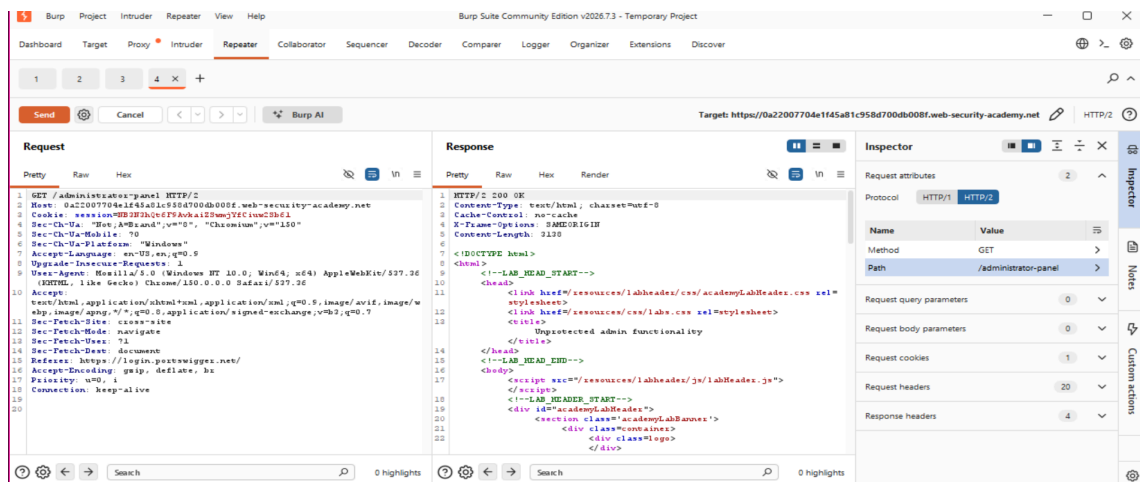
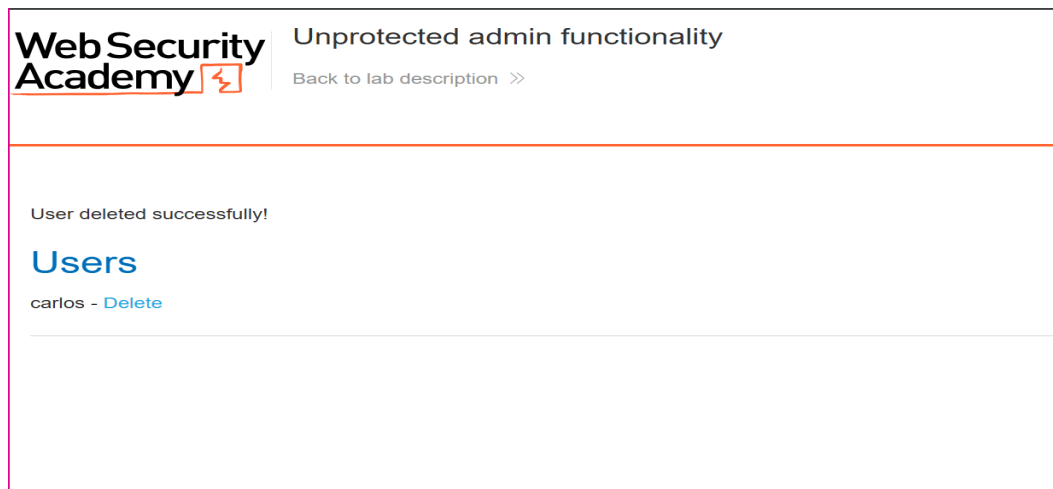


Figure 1.2: Browser confirmation view demonstrating successful unauthorized user deletion (User deleted successfully!):



3.2. Finding 2: Security Misconfiguration

- **Vulnerability Title:** Unrestricted Directory Listing at /ftp
- **Severity Rating:** Medium
- **Affected Endpoint:** /ftp
- **Testing Methodology:**
 - The target endpoint /ftp was navigated to using the Burp Suite Built-in Browser.
 - HTTP response headers and body content were examined in Burp Repeater.
 - Directory indexing behavior was verified.
- **Detailed Observation:**

The web server configuration permits default directory listing (indexing) on the /ftp folder. Navigating to this path exposes raw file structures and reveals sensitive internal backup files, configuration notes, and system logs (i.e. acquisitions.md, coupons_2013.md.bak, and suspicious_errors.yml).
- **Business Impact :**

Exposing internal backup files and system directory listings allows external attackers to gather intelligence on proprietary application logic, internal database structure, and deprecated credentials, facilitating secondary targeted exploits against payment processing or ordering gateways.
- **Remediation Strategy:**
 - **Disable Directory Browsing:** Turn off directory indexing globally in the web server configuration (e.g., set Options -Indexes in Apache or disable autoindex in Nginx/IIS).
 - **Restrict File System Access:** Ensure sensitive files and backups are stored outside the public web root directory.

Proof of Concept Evidence (A05):

Figure 2.1: Burp Suite Repeater response showing directory listing content at /ftp:

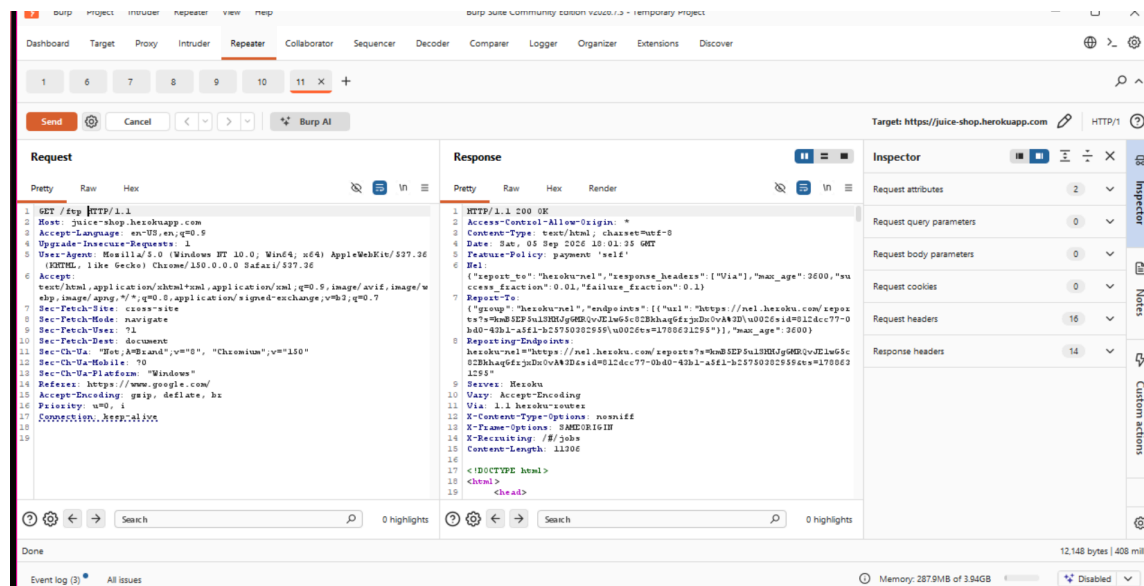
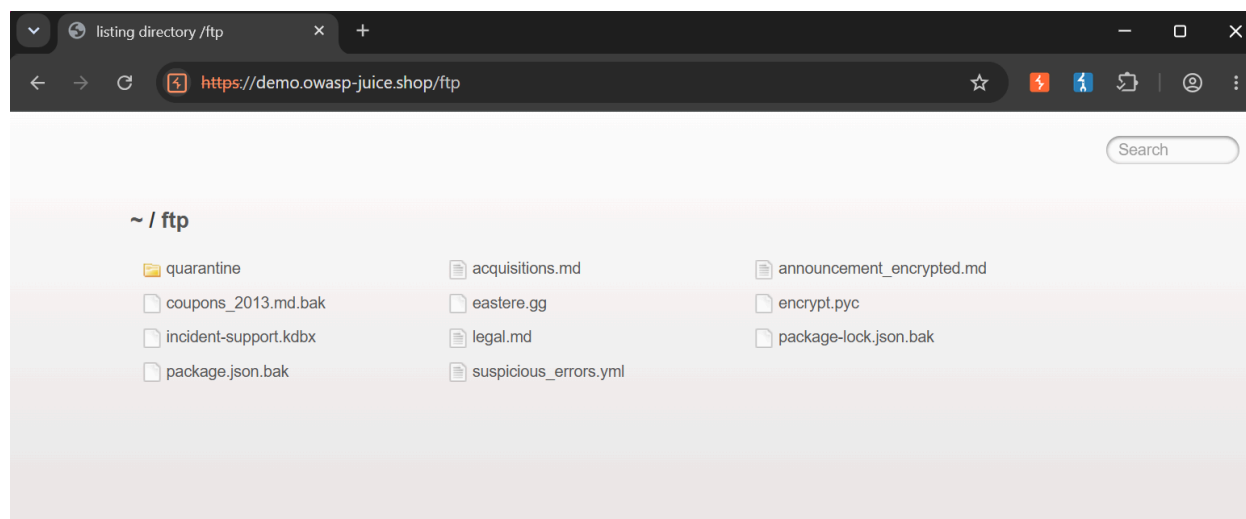


Figure 2.2: Browser view showing exposed /ftp directory structure and internal backup files:



4. Conclusion & Action Plan

- 1. Immediate Action (Priority High):** Implement server-side authorization middleware across all administrative endpoints (/administrator-panel) to prevent unauthorized access and privilege escalation.
- 2. Secondary Action (Priority Medium):** Harden web server configurations by globally disabling directory indexing and restricting public access to system folders like /ftp.

AUTHOR INFORMATION

Author Information	Project Metadata
Name: Mishal Haider	Program: Cybersecurity Internship
Role: Cybersecurity Professional	Organization: Safex